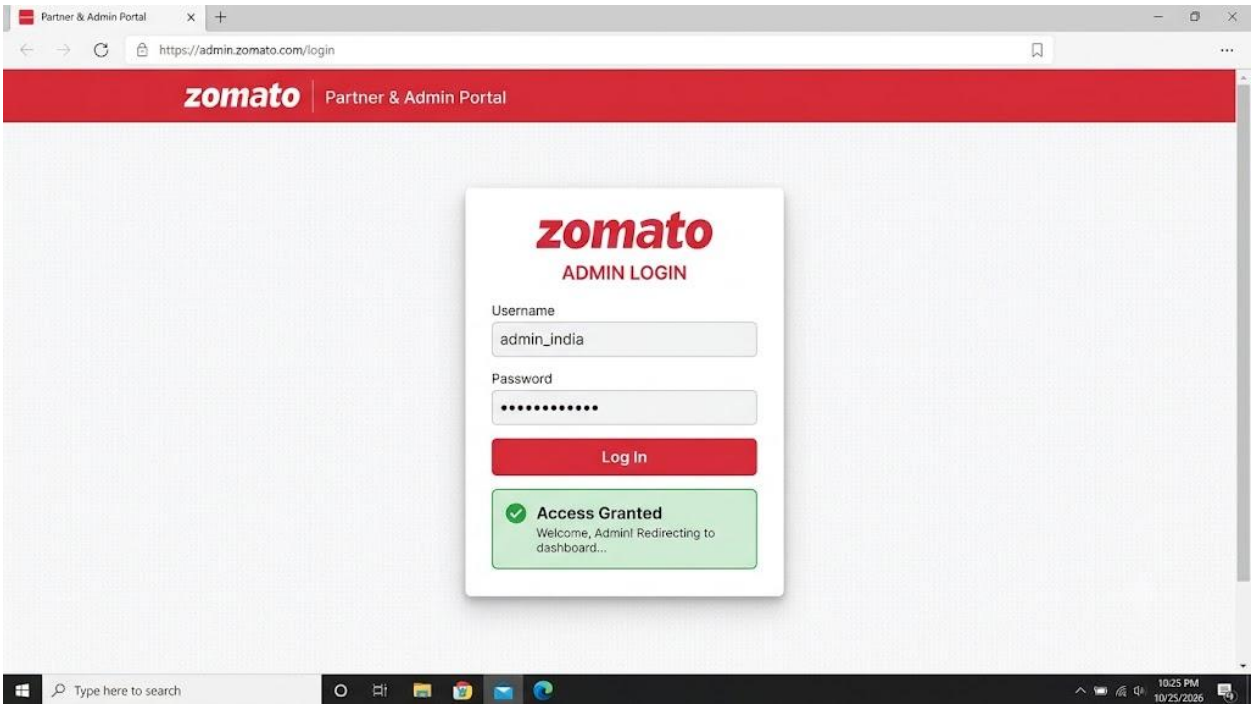
o

Assignment 3

Authentication & Access Control

1. **Create a simple login form for a mock Zomato admin panel that asks for username and password, then displays 'Access Granted' only if both fields match hardcoded admin credentials.**



2. **Write a Python function check_access(user_role, resource) that returns True if the user_role is allowed to access the resource, otherwise False. Test it with roles like 'customer', 'restaurant_owner', and resources like 'menu_edit', 'order_history', 'admin_dashboard'. Hint: Use a dictionary to map roles to allowed resources.**

❖ **create a Python function that checks whether a user role is allowed to access a particular resource.**

➢ **Python Program**

```
# DEFINE ROLES AND THEIR ALLOWED RESOURCES
PERMISSIONS = {
  "CUSTOMER": ["ORDER_HISTORY"],
  "RESTAURANT_OWNER": ["MENU_EDIT", "ORDER_HISTORY"],
  "ADMIN": ["MENU_EDIT", "ORDER_HISTORY", "ADMIN_DASHBOARD"]
}
# FUNCTION TO CHECK ACCESS
DEF CHECK_ACCESS(USER_ROLE, RESOURCE):
  IF RESOURCE IN PERMISSIONS.GET(USER_ROLE, []):
    RETURN TRUE
```

```
    return False

# Test the function
print(check_access("customer", "order_history"))
print(check_access("restaurant_owner", "menu_edit"))
print(check_access("customer", "admin_dashboard"))
print(check_access("admin", "admin_dashboard"))
```

➢ Output

```
True
True
False
True
```

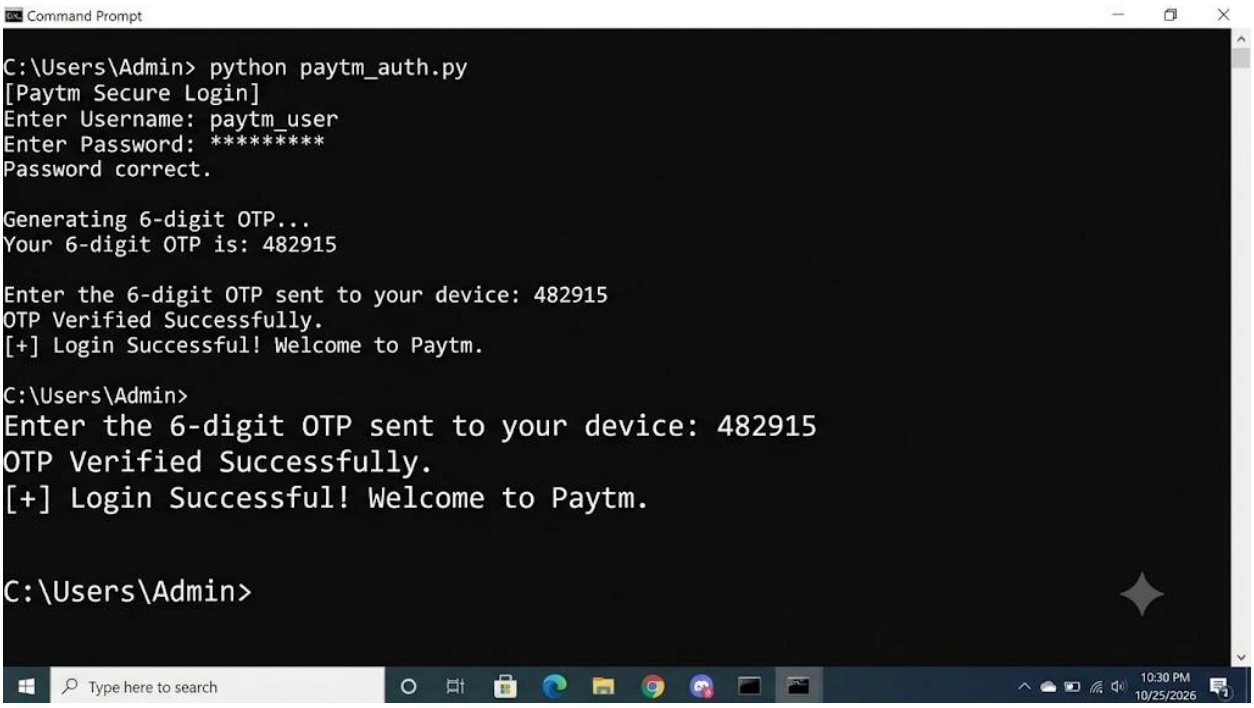
➢ Explanation

A dictionary stores the resources allowed for each role.

The function checks whether the requested resource is in the user's allowed list.

It returns True if access is allowed and False otherwise.

3. **Simulate a two-factor authentication flow like Paytm: after a user enters the correct password, generate a 6-digit OTP and display it in the console. Ask the user to input the OTP and display 'Login Successful' only if it matches.**



4. **Given an array of user objects with properties: username, isPremium, and lastLogin, write a function that returns only those users who are premium and have logged in within the last 7 days. Constraint: Assume lastLogin is a date string in 'YYYY-MM-DD' format, and today is '2024-06-10'.**

Example code

```
const users = [
 { username: "vir", isPremium: true, lastLogin: "2024-06-08" },
 { username: "rahul", isPremium: false, lastLogin: "2024-06-09" },
 { username: "aman", isPremium: true, lastLogin: "2024-05-20" },
 { username: "riya", isPremium: true, lastLogin: "2024-06-05" }
];
function filterPremiumUsers(users) {
 const today = new Date("2024-06-10");
 const sevenDaysAgo = new Date("2024-06-03");
 return users.filter(user => {
  const loginDate = new Date(user.lastLogin);
  return user.isPremium &&
      loginDate >= sevenDaysAgo &&
      loginDate <= today;
 });
}
console.log(filterPremiumUsers(users));
```

➢ Output

```
[
 { username: "vir", isPremium: true, lastLogin: "2024-06-08" },
 { username: "riya", isPremium: true, lastLogin: "2024-06-05" }
]
```

Result: The function returns only premium users who logged in between June 3 and June 10, 2024, inclusive.

5. **Use ChatGPT to generate a list of 5 common access control mistakes developers make in real-world apps like Instagram or Flipkart, and for each, write a one-line fix or prevention tip.**

No.	Access Control Mistake	Fix / Prevention Tip
1.	Weak Passwords: Users choose easy-to-guess passwords.	Enforce strong passwords and use secure password hashing.
2.	Broken Access Control: Users access data or pages they are not authorized to view.	Check user permissions on every protected request.
3.	Missing Authentication: Sensitive pages are accessible without logging in.	Require authentication before granting access to protected resources.
4.	Excessive Permissions: Users receive more access than they need.	Follow the principle of least privilege and grant only necessary permissions.
5.	Insecure Session Management: Attackers misuse stolen or exposed login sessions.	Use secure session cookies and expire sessions after logout or inactivity.